TESTE03 - Qwen3.5

==========

SERVIDOR MCP

==========

Servidor MCP conectado.

Aguardando resposta do servidor...
Tempo de espera: 806 segundos

==========

RESPOSTA DO SERVIDOR

==========

Relatório de Segurança — fiware/orion

Resumo da Varredura:

- Blocos analisados: 11
- Vulnerabilidades descartadas (FIXED): 654

Análises Detalhadas

Parte 1 de 11

Análise de Segurança: fiware/orion (Debian 13.4)

Vulnerabilidades Relevantes Identificadas

ID da Vulnerabilidade	Pacote(s) Afetado(s)	Versão Atual Instalada	Severidade
CVE-2026-76642	`bsdutils`, `libblkid1`	1:2.41-5 / 2.41-5	HIGH
CVE-2026-78408	`bsdutils`, `libblkid1`	1:2.41-5 / 2.41-5	HIGH
CVE-2026-78409	`bsdutils`, `libblkid1`	1:2.41-5 / 2.41-5	HIGH
CVE-2026-78410	`bsdutils`	1:2.41-5	HIGH
CVE-2026-12064	`curl`	8.14.1-2+deb13u2	HIGH
CVE-2026-8458	`curl`	8.14.1-2+deb13u2	HIGH

ID da Vulnerabilidade	Pacote(s) Afetado(s)	Versão Atual Instalada	Severidade
CVE-2026-54369	`libacl1`	2.3.2-2+b1	HIGH

Impacto Provável

1. **Escalação de Privilégios Crítica (Util-linux):** As vulnerabilidades nos pacotes `bsdutils` e `libblkid1` permitem que usuários locais não autorizados executem operações privilegiadas via hooks de montagem (`X-mount`), manipulação de cgroups do root, e travessia de links simbólicos para acesso indevido ao sistema de arquivos.
2. **Falha na Verificação de Identidade (Curl):** O pacote `curl` pode conectar a hosts SSH não verificados (bypass de chave) e reutilizar conexões autenticadas incorretamente, facilitando ataques *Man-in-the-Middle* e roubo de credenciais.
3. **Manipulação de Permissões (Libacl1):** A biblioteca `libacl1` permite travessia por links simbólicos em funções de ACL, possibilitando a modificação não autorizada de listas de controle de acesso e escalonamento de privilégios local.

Recomendações de Correção Práticas

1. **Atualização Imediata dos Pacotes:** A correção primária é aplicar as atualizações de segurança oficiais do Debian para a versão 13.x (Trixie). Execute o seguinte comando em ambiente seguro:

```
apt update && apt upgrade bsdutils libblkid1 curl libacl1 -y
```

2. **Verificação de Dependências:** Após a atualização, verifique se há pacotes orphans ou se dependências críticas foram sobrescritas.
3. **Hardening de Montagem:** Enquanto aguarda atualizações (se não estiver disponível), revise as entradas `/etc/fstab` e desabilite opções `X-mount` perigosas (`idmap` , `owner` , `subdir`) até a correção da vulnerabilidade do util-linux.
4. **Monitoramento de Rede:** Como o `curl` tem falhas de verificação SSH, audite os fluxos de rede que utilizam scripts de automação ou ferramentas de backup dependentes do `curl` .

Parte 2 de 11

Análise de Segurança: fiware/orion (Debian 13.4)

Vulnerabilidades Relevantes Identificadas

- **CVE-2026-78410:** Pacotes `libblkid1`, `liblastlog2-2`. Risco de redirecionamento de montagem (`bind mount`).
- **CVE-2026-12064:** Pacote `libcurl4t64`. Bypass na verificação de host SSH.
- **CVE-2026-8458:** Pacote `libcurl4t64`. Reutilização indevida de conexões autenticadas.
- **CVE-2026-76642:** Pacotes `liblastlog2-2`, `libmount1`. Escalada de privilégios via hooks de montagem falhos.
- **CVE-2026-78408:** Pacotes `liblastlog2-2`, `libmount1`. Vazamento de autoridade de migração de cgroup como root.
- **CVE-2026-78409:** Pacotes `liblastlog2-2`, `libmount1`. Escape de resolução de symlinks em montagens.

Impacto Provável

Todos os vetores possuem severidade **HIGH**. O sistema corre risco de:

- **Escalada de Privilégios:** Usuários não privilegiados podem executar operações com privilégios de root ou alterar permissões de arquivos críticos (SUID).
- **Quebra de Confidencialidade/Integridade SSH:** Conexões não verificadas a hosts remotos durante transferências SFTP/SCP.
- **Comprometimento de Isolamento:** Possibilidade de migração e término de processos do root em outros namespaces via cgroups.
- **Violação de Montagens:** Ataques através de symlinks intermediários ou redirecionamento de caminhos de sistema de arquivos.

Recomendações de Correção

1. **Atualização Imediata:** Aplique as atualizações do repositório Debian para os pacotes críticos: `libblkid1`, `libcurl4t64`, `liblastlog2-2` e `libmount1`.
   ```
   apt update && apt full-upgrade
   ```
2. **Validação de Pacotes:** Verifique se o pacote `util-linux` foi atualizado, visto que todas as CVEs associadas a ele (`util-linux`) são listadas nas descrições.
3. **Monitoramento:** Mantenha habilitada a atualização automática para evitar a exposição a essas vulnerabilidades futuras (e passadas, dado o ano 2026 nos IDs).
4. **Redução de Superfície:** Evite configurações complexas de montagem (`fstab`) que utilizem opções experimentais como `X-mount.owner` até que os patches sejam aplicados.

Parte 3 de 11

Análise de Segurança: fiware/orion (Debian 13.4)

Vulnerabilidades Relevantes:
As varreduras identificam múltiplos CVEs com severidade **HIGH** nos seguintes pacotes:

- **CVE-2026-78410**: Afecta `libmount1`.
- **CVE-2026-76642, CVE-2026-78408, CVE-2026-78409**: Afectam `libsmartcols1` e `libuuid1` (suíte `util-linux`).
- **CVE-2026-16742**: Afecta `libsystemd0` e `libudev1`.
- **CVE-2025-69720**: Afecta `libtinfo6`.

Impacto Provável:

- **Escalonamento de Privilégios:** Usuários locais não privilegiados podem obter privilégios de root através da manipulação de montagens, hooks X-mount e verificação falha em home-managed users.
- **Execução de Código Arbitrário:** Vulnerabilidade de buffer overflow no pacote `ncurses` permite execução remota ou local de código (RCE).
- **Violação de Isolamento:** Vazamento de autoridade de migração de cgroups (root), permitindo a terminação ou movimento de processos críticos protegidos.

Recomendações de Correção Práticas:

1. **Atualização Imediata:** Execute `apt update && apt upgrade` para aplicar patches das versões da família `util-linux`, `systemd` e `ncurses`.
2. **Verificação de Dependências:** Garanta que as versões instaladas (ex: 2.41-5, 257.9-1) sejam substituídas pelas versões corretivas disponíveis nos repositórios do Debian 13.4.
3. **Monitoramento Contínuo:** Implemente uma rotina de escaneamento semanal para evitar regressão de segurança e garantir que o sistema permaneça dentro do baseline seguro pós-correção.

Parte 4 de 11

Análise de Segurança: fiware/orion (debian 13.4)

1. Vulnerabilidades Identificadas

A imagem apresenta vulnerabilidades distribuídas entre os pacotes `linux-libc-dev` e `libuuid1`.

ID da Vulnerabilidade	Pacote	Severidade	Resumo do Problema
CVE-2026-43185	linux-libc-dev	**CRITICAL**	Heap buffer overflow no `ksmbd` (exploitável).
CVE-2026-78409	libuuid1	HIGH	Escape de resolução de symlinks em montagens (`X-mount.subdir`).
CVE-2026-78410	libuuid1	HIGH	Redirecionamento de fontes em bind mounts restritos.
CVE-2024-21803	linux-libc-dev	HIGH	Use-after-free no módulo Bluetooth (`af_bluetooth.c`).
CVE-2024-58015	linux-libc-dev	HIGH	Acesso fora de limites na rede Wi-Fi (`ath12k`).
CVE-2021-3847	linux-libc-dev	HIGH	Escalação de privilégios no OverlayFS.
CVE-2021-3864	linux-libc-dev	HIGH	Configuração perigosa em dumps de SUID (escalação).
CVE-2019-19449/19814	linux-libc-dev	HIGH	Acesso fora de limites na montagem F2FS.
CVE-2013-7445	linux-libc-dev	HIGH	Exaustão de memória via GEM no DRM.

2. Impacto Provável

- **Escalação de Privilégios:** Vulnerabilidades críticas (CVE-2026-43185, CVE-2021-3847, CVE-2021-3864) permitem que usuários locais ou atacantes remotos elevem privilégios até root.
- **Execução de Código Malicioso:** Falhas de buffer overflow (CVE-2026-43185, CVE-2024-21803) e erros de alocação permitem execução arbitrária de código no sistema local.
- **Negativação de Serviço (DoS):** Exaustão de memória e falhas em módulos de rede podem travar o kernel ou serviços críticos.
- **Quebra de Isolamento:** Vulnerabilidades de montagem (`libuuid1`) permitem que usuários maliciosos acessem ou alterem diretórios do sistema host através de mountpoints autorizados.

3. Recomendações de Correção

Para mitigar os riscos identificados:

1. **Atualização Imediata:** Atualize urgentemente o pacote `linux-libc-dev` (atualmente `6.12.74-2`) para resolver falhas críticas e altas no kernel. Faça o mesmo para `libuuid1` (versão `2.41-5`).
2. **Revisão de Montagem:** Verifique entradas `fstab` que utilizam opções como `X-mount.subdir` ou `X-mount.owner`, especialmente em ambientes onde usuários não-root possuem permissões de escrita para essas pastas.
3. **Avaliação de Rede:** Como existem vulnerabilidades em módulos Wi-Fi (`ath12k`) e Bluetooth, considere isolar a interface de rede do módulo Wi-Fi se não for essencial para o funcionamento da aplicação `fiware/orion`.
4. **Patch Management:** Configure atualizações automáticas ou agendadas para o pacote `linux-libc-dev`, dado o alto volume de vetores de ataque expostos neste kernel versionado.

Parte 5 de 11

Análise de Segurança - fiware/orion (debian 13.4)

Versão Atual Detectada:

- **Pacote:** `linux-libc-dev`
- **Versão Instalada:** `6.12.74-2`

Vulnerabilidades Relevantes e Impactos:

ID CVE	Nome do Pacote	Impacto Provável (Com base na descrição)	Severidade
CVE-2025-38137	`linux-libc-dev`	**Use-after-free:** Liberação prematura de memória no subsistema PCI, permitindo execução não autorizada ou corrupção.	HIGH
CVE-2025-38187	`linux-libc-dev`	**Use-after-free:** Driver gráfico nouveau permite leitura/escrita após liberação de contêiner RPC.	HIGH
CVE-2025-38204	`linux-libc-dev`	**Out-of-bounds Read:** Leitura além dos limites na fila JFS, podendo corromper dados do sistema de arquivos.	HIGH
CVE-2025-	`linux-libc-dev`	**Double Free:** Liberação dupla na gerenciamento PMF da AMD, levando à instabilidade ou crash.	HIGH

ID CVE	Nome do Pacote	Impacto Provável (Com base na descrição)	Severidade
38421			
CVE-2025-38636	`linux-libc-dev`	**Out-of-bounds:** Acesso a memória global fora de limites em tracepoints do kernel (KASAN).	HIGH
CVE-2025-39859	`linux-libc-dev`	**Use-after-free:** Condições de corrida no watchdog PTP/OCp causam acesso após liberação.	HIGH
CVE-2025-39862	`linux-libc-dev`	**List Corruption:** Corrupção de listas na rede Wi-Fi (mt7915) após reinício, risco de falha de sistema.	HIGH
CVE-2025-39958	`linux-libc-dev`	**Erro Lógico/IOMMU:** Falha na anexação de dispositivo removeido inesperadamente, podendo causar erro de advertência (WARN_ON).	HIGH
CVE-2025-40025	`linux-libc-dev`	**Kernel Panic/Crash:** Leitura de dnode incorreta no F2FS causando "invalid opcode" e panic sob fuzzing.	HIGH
CVE-2025-68174	`linux-libc-dev`	**Race Condition/DoS:** Condição de corrida no AMD KFD (compartilhamento de processamento) levando a *divide error* e crash do sistema.	HIGH

Recomendações Práticas:

1. **Atualização Imediata:** Todas as vulnerabilidades afetam o pacote `linux-libc-dev` e, por consequência, o kernel binário associado (`linux-image` , `linux-modules`). Realize uma atualização imediata dos pacotes de kernel para aplicar os patches de segurança do upstream Linux.
2. **Comando de Atualização:** Execute a atualização do repositório e reinicie o sistema:

```
apt update && apt dist-upgrade -y
reboot
```

3. **Verificação Pós-Upgrade:** Após o reboot, verifique a versão instalada do kernel (`uname -r`) para garantir que corresponde à versão corrigida disponível nos repositórios da Debian 13 (Trixie).
4. **Monitoramento:** Como as vulnerabilidades envolvem uso após liberação de memória e falhas de sistema, o monitoramento de logs do `kernel` ou `syslog` é essencial para detectar reinícios anômalos ou crashes até a aplicação da correção.

Parte 6 de 11

Análise de Segurança: fiware/orion (Debian 13.4)

Resumo

O sistema `fiware/orion` está executando a versão **6.12.74-2** do pacote `linux-libc-dev`. A análise identificou **10 vulnerabilidades críticas de alta gravidade**, todas relacionadas ao núcleo do kernel Linux, introduzindo riscos de elevação de privilégio, Denial of Service (DoS), vazamento de memória e corrupção de dados.

Lista de Vulnerabilidades

CVE ID	Pacote Afetado	Impacto Provável	Recomendação Prática
CVE-2025-68735	`linux-libc-dev`	**Elevação de Privilégio**: Use-after-free no subsistema DRM/panthor permite execução remota de código.	Atualizar para versão corrigida do kernel (`linux-image` , `linux-libc-dev`).
CVE-2026-23102	`linux-libc-dev`	**Denial of Service (DoS)**: Restauração incorreta de contexto SVE causa leitura fora dos limites ou morte da tarefa (SIGKILL).	Atualizar pacote `linux-libc-dev` imediatamente.
CVE-2026-23208	`linux-libc-dev`	**Corrupção de Memória**: Leitura/Escrita fora dos limites na camada ALSA USB (OOM/Bug KASAN).	Aplicar atualização de kernel correspondente ao pacote.
CVE-2026-23327	`linux-libc-dev`	**Vazamento de Memória/Leitura OOB**: Acesso indevido a payload em mailbox CXL sem validação de tamanho.	Atualizar kernel e componentes de memória (CXL).
CVE-2026-31493	`linux-libc-dev`	**Inestabilidade do Kernel**: Uso de contexto após liberação no RDMA/efa.	Atualizar subsistema RDMA via atualização do kernel.
CVE-2026-31536	`linux-libc-dev`	**Corrupção de Estado**: Tratamento inadequado de conclusões no SMB Server (IBM).	Corrigir mediante atualização da suite do kernel.
CVE-2026-31568	`linux-libc-dev`	**Loop Infinito/Kernel Hang**: Exceções de acesso a armazenamento seguro na arquitetura s390.	Atualizar pacote específico para fixação em memória segura.
CVE-2026-	`linux-libc-`	**Crash do Sistema**: Referência nula no media chips-media (Wave5).	Atualizar drivers de mídia e kernel.

CVE ID	Pacote Afetado	Impacto Provável	Recomendação Prática
43263	`dev`		
CVE-2026-46130	`linux-libc-dev`	**Vazamento/Denial of Service**: Leitura fora dos limites em verificação de integridade dm-verity-fec.	Atualizar subsistema de integridade do disco (`dm-verity`).
CVE-2026-46181	`linux-libc-dev`	**Crash/Instabilidade**: Uso incorreto de RCU em RDMA/mlx4.	Atualizar drivers de hardware de rede (RDMA) e kernel.

Recomendações Gerais de Correção

1. **Atualização do Kernel:** Todas as vulnerabilidades residem no núcleo do Linux. A correção eficaz exige a atualização de `linux-libc-dev` junto com os pacotes dependentes, como `linux-image` , `linux-headers` e módulos específicos (`firmware-linux-non-free`).
2. **Sistema de Gerenciamento:** Execute uma atualização completa dos pacotes no sistema Debian (ex: `apt update && apt full-upgrade`) para garantir que todas as bibliotecas de desenvolvimento do kernel e o núcleo em si recebam os patches.
3. **Verificação de Hash/Checksums:** Após a atualização, verifique as assinaturas digitais dos binários de segurança para garantir integridade contra falsificações.
4. **Monitoramento:** Monitore logs (`/var/log/kern.log` , `dmesg`) em busca de mensagens de erro relacionadas aos IDs das vulnerabilidades (ex: KASAN splats) até a confirmação da atualização.

Conclusão

A versão instalada (6.12.74-2) é considerada **insegura** devido à combinação de falhas de uso após liberação (UAF), violações de isolamento de memória e potencialidades de DoS. A correção prioritária é a atualização da imagem de sistema ou dos pacotes do kernel até uma versão que não contenha estes CVEs listados.

Parte 7 de 11

Análise de Segurança: fiware/orion (Debian 13.4)

Vulnerabilidades Relevantes

- **Pacote Alvo:** `linux-libc-dev` (Versão Instalada: 6.12.74-2)
- **ID das CVEs Identificadas (HIGH):**

- CVE-2026-46279
- CVE-2026-52991
- CVE-2026-53000
- CVE-2026-53091
- CVE-2026-53109
- CVE-2026-53118
- CVE-2026-53277
- CVE-2026-53330
- CVE-2026-63879
- CVE-2026-64283

Impacto Provável

- **Falhas de Memória e Execução Remota:** Múltiplas vulnerabilidades apontam para Use-After-Free (UAF), como no subsistema `sched/psi` e `vdpa`, permitindo potencialmente execução arbitrária de código após a liberação incorreta de objetos.
- **Leitura Fora dos Limites (Buffer Overflow):** Acidental em acessos à tabela de capacidades de DisplayPort (`drm/amd/display`) e falhas na validação de tamanhos e offsets no subsistema KVM (`guest_memfd`).
- **Instabilidade do Kernel:** Erros de estado de página (bad page state) no PowerPC e race conditions entre operações de arquivos e gravação de pressão, causando crashes ou deadlocks no boot.
- **Segurança da Rede:** Problemas na liberação de hooks nat (`netfilter`) e tratamento inadequado de pacotes GSO podem facilitar ataques de injeção via rede.

Recomendações de Correção Práticas

1. **Atualização Imediata do Pacote:** Aplique as atualizações de segurança imediatamente para o pacote `linux-libc-dev`.

   ```
   sudo apt update && sudo apt upgrade linux-libc-dev
   ```

2. **Reinicialização do Sistema:** Como a vulnerabilidade reside no núcleo (kernel), após a atualização, é necessário reiniciar o servidor para carregar as bibliotecas e patches do kernel corrigidos.
3. **Verificação de Dependências:** Confirme que pacotes dependentes de imagem do kernel (`linux-image-*` , `linux-headers-*`) também sejam atualizados para compatibilidade.
4. **Monitoramento:** Após a correção, monitore os logs do kernel (`/var/log/kern.log` ou `/var/log/messages`) por alertas relacionados às CVEs listadas (ex: mensagens de KASAN ou warnings de memória) durante a primeira carga após o update.

Análise de Vulnerabilidades - fiware/orion

1. Resumo do Escopo

- **Sistema Alvo:** fiware/orion (Debian 13.4)
- **Pacote Crítico Afetado:** `linux-libc-dev` (Versão instalada: `6.12.74-2`)
- **Total de Vulnerabilidades Detectadas:** 10

2. Vulnerabilidades Identificadas (ID e Pacote)

Todas as falhas afetam o pacote `linux-libc-dev`. Abaixo, a lista dos IDs CVE identificados no relatório:

1. **CVE-2026-68409:** kernel: wifi: mac80211 (Race condition em liberação de memória)
2. **CVE-2026-68426:** kernel: xfrm (Use-after-free ao processar GSO segments)
3. **CVE-2026-68470:** kernel: wifi: mac80211 (Falha na validação de frames de extensão)
4. **CVE-2026-72042:** kernel: ipmi (Underflow de contador de referência do usuário)
5. **CVE-2026-72098:** kernel: dm-verity (Buffer Overflow no cálculo FEC/decodificação)
6. **CVE-2026-72463:** kernel: xfrm (Use-after-free em resumo assíncrono de dispositivo)
7. **CVE-2026-74269:** kernel: bnxt (Underflow ao ajustar cabeçalho XDP, potencial double free)
8. **CVE-2026-74520:** kernel: iommu/iommufd (Use-after-free em grupos IOPF)
9. **CVE-2026-74752:** kernel: sctp (Leitura fora de limites e escrita inválida em AUTH states)
10. **CVE-2026-89631:** kernel: smb (Corrupção de heap e acesso a memória via ByteCount pequeno)

3. Impacto Provável

- **Estabilidade do Sistema:** Risco alto de DoS (Denial of Service), crashes e reinicializações não solicitadas devido a vazamentos de referência e corrupção de memória.
- **Segurança:** Risco de Escape de Privilegios Locais e Execução de Código Remoto (RCE). Falhas de *Use-After-Free* (UAF) e *Buffer Overflow* permitem que atacantes manipulem a estrutura de memória do kernel para injetar código ou acessar dados protegidos.
- **Dados Sensíveis:** Risco de exposição de informações através de respostas SMB inválidas contendo dados de usuários ou sistemas de arquivos via `/proc`.

4. Recomendações de Correção

1. **Atualização Imediata:** Aplique o patch do pacote `linux-libc-dev` imediatamente após a liberação da nova versão na repositório oficial Debian 13.4 (`apt update && apt upgrade`

`linux-libc-dev`).

2. **Reinicialização:** Realize um *reboot* obrigatório após a atualização para garantir que as novas versões do kernel e subsistemas (wifi, xfrm, iommu) estejam carregadas corretamente.
3. **Verificação Pós-Atualização:** Confirme via `dpkg -l linux-libc-dev` que o pacote instalado possui uma versão superior à `6.12.74-2`.
4. **Monitoramento:** Monitorar *logs* do kernel (`/var/log/kern.log`) por mensagens de erro de memória ou pânico para validar a estabilidade após o patch.

Parte 9 de 11

Análise de Segurança: fiware/orion (debian 13.4)

Pacote Afetado: `linux-libc-dev` (Versão instalada: 6.12.74-2)

Vulnerabilidades Identificadas:
O pacote `linux-libc-dev` está vulnerável a 10 CVEs classificados com **Gravidade HIGH**.

ID da Vulnerabilidade	Impacto Probável (Resumo do Escopo)
CVE-2026-89633	Correção de memória OOB (SMB Client): Leitura/escrita fora dos limites na heap. Risco de Execução de Código Remota ou DoS.
CVE-2026-89638	Persistência de bits setuid/setgid ao escrever arquivos em mounts CIFS/NFS específicos. Permite elevação não autorizada de privilégios (Privilege Escalation).
CVE-2026-89675	Use-After-Free (UAF) no daemon NFS (`nfsd`). Risco de corrupção de kernel ou DoS via requisições assíncronas.
CVE-2026-89811	Falha de sincronização TLB em GPU AMD KFD. Pode causar hangs do driver de GPU e acesso a memória desalocada (DoS).
CVE-2026-89972	Uso de SRCU incorreto na remoção de namespace NVMe. Risco de Use-After-Free em operações de armazenamento multipath.
CVE-2026-90111	Clone de `dst` incorreto em reportes multicast IPv6. Triggera Use-After-Free ao processar pacotes de rede (DoS ou Exec).
CVE-2026-90315	Ausência de checks de lockdown em handlers legacy PCI Permite escrita arbitraria em I/O e acesso a memória apesar do kernel locked down.
CVE-2026-97528	Falha ao remover nó da lista antes de liberar contexto NVMe na HBA QLogic. Risco de corrupção de lista e crash (UAF).

ID da Vulnerabilidade	Impacto Probável (Resumo do Escopo)
CVE-2026-98222	Desbordamento inteiro (`datablob_len`) no manuseio de chaves criptografadas. Risco de Write After Bounds Slab.
CVE-2026-98260	Limpeza tardia de timers POSIX após `de_thread()` . Uso pós-liberação (UAF) em timers que pode levar a crash ou DoS.

Impacto Geral:
O sistema enfrenta riscos críticos de **Execução de Código**, **Elevação de Privilégios** e **Denial of Service (DoS)** devido a múltiplos falhas de gerenciamento de memória (UAF, OOB), contornamento de lockdown de segurança e instabilidade em drivers de hardware (GPU, NVMe, SCSI).

Recomendações de Correção:

1. **Atualização Imediata:** Aplique o pacote `linux-libc-dev` com a versão mais recente disponível nos repositórios oficiais de segurança para Debian 13.4 que contenha os patches correspondentes a estes CVEs.
2. **Rollback e Verificação:** Após a atualização, verifique a versão instalada via comando `dpkg -l linux-libc-dev` para confirmar que ela excede o limite seguro da versão 6.12.74-2 (baseado nos números de commit/fixa nas descrições).
3. **Reboot Opcional:** Dadas as falhas no núcleo (`linux-libc-dev`), pode ser necessário reiniciar o serviço do kernel ou a máquina para que os novos drivers e módulos de segurança sejam carregados corretamente.

Parte 10 de 11

Análise de Segurança: fiware/orion (Debian 13.4)

Resumo Executivo
Identificadas múltiplas vulnerabilidades classificadas como **HIGH**. O sistema apresenta riscos críticos de execução remota de código, elevação de privilégios e instabilidade no kernel Linux e na suíte util-linux.

---

1. Vulnerabilidades Identificadas

CVE ID	Pacote(s) Afetado(s)	Versão Instalada	Categoria de Risco
CVE-2026-98320	`linux-libc-dev`	6.12.74-2	Núcleo (Kernel) / Use-after-free
CVE-2026-98323	`linux-libc-dev`	6.12.74-2	Rede (RDMA) / OOB Write
CVE-2026-98364	`linux-libc-dev`	6.12.74-2	Rede (XFRM) / Use-after-free
CVE-2026-98378	`linux-libc-dev`	6.12.74-2	BPF / Use-after-free
CVE-2026-76642	`login`, `mount` (util-linux)	1:4.16.0-2+really2.41-5 / 2.41-5	Sistema de Arquivos / Esvaziamento de Privilégios
CVE-2026-78408	`login`, `mount` (util-linux)	1:4.16.0-2+really2.41-5 / 2.41-5	Controle Cgroup / Esvaziamento de Privilégios
CVE-2026-78409	`login`, `mount` (util-linux)	1:4.16.0-2+really2.41-5 / 2.41-5	Sistema de Arquivos / Escape de Caminho (Symlink)
CVE-2026-78410	`login`, `mount` (util-linux)	1:4.16.0-2+really2.41-5 / 2.41-5	Sistema de Arquivos / Redirecionamento de Mount SUID

---

2. Impacto Provável

- **Kernel (`linux-libc-dev`):** Possibilidade de **Execução Remota de Código (RCE)** e **Negação de Serviço (DoS)** através de falhas de gerenciamento de memória (Use-after-free, OOB write). Isso permite que um atacante manipule conexões de rede ou inicie execuções maliciosas no contexto do kernel.
- **Util-linux (`login` / `mount`):** Alto risco de **Elevação de Privilégios**. Usuários não privilegiados podem forçar o carregamento de SUID bits, modificar permissões de inodes raiz e migrar processos da sessão `root` para grupos não autorizados.
- **Ambiental:** O sistema está exposto a ataques em nível local e remoto, comprometendo a integridade da rede e dos dados.

---

3. Recomendações de Correção Práticas

Aplicue as atualizações imediatamente (`apt update && apt upgrade`):

1. **Atualizar Núcleo Linux:**
   - Forneça um pacote de atualização para `linux-libc-dev` (alvo: versão superior à 6.12.74-2).
2. **Atualizar Util-linux:**
   - Atualize os pacotes `login` , `mount` e a suíte util-linux principal para versões que superem os CVEs listados (versões posteriores a 2.41.5 ou 2.42.2, conforme especificado nas descrições).
3. **Validação:**
   - Após o upgrade, verifique os hashes dos pacotes e reinicie serviços de rede (`systemctl restart networking`) para garantir que os patches de rede (netfilter/rdma/xfrm) estejam ativos sem interromper a conectividade.
4. **Monitoramento:**
   - Ative alertas para novos CVEs no kernel Linux, dado o histórico de vulnerabilidades em versões antigas de 6.12.x.

Parte 11 de 11

Vulnerabilidades Relevantes

- **CVE-2026-78409:** Pacotes `mount` e `util-linux` . Risco: Escape de resolução via symlinks intermediários.
- **CVE-2026-78410:** Pacote `mount` . Risco: Redirecionamento de fontes em bind mounts restritos, permitindo alteração de ownership root.
- **CVE-2025-69720:** Pacotes `ncurses-base` e `ncurses-bin` . Risco: Execução de código arbitrário via *buffer overflow* no `infocmp` .
- **CVE-2026-9538:** Pacote `perl-base` . Risco: Negação de serviço (DoS) por consumo excessivo de memória via cabeçalhos `.tar` malformados.
- **CVE-2026-76642:** Pacote `util-linux` . Risco: Escalonamento de privilégios; hooks privilegiados rodam mesmo se o helper externo falhar.
- **CVE-2026-78408:** Pacote `util-linux` . Risco: Vazamento de autoridade de migração de cgroup, permitindo terminação de processos do root por usuários não privilegiados.

Impacto Provável

- **Comprometimento de Privilegios:** Usuários locais podem executar comandos como root (Escalonamento).
- **Execução de Código Remoto/Local:** Possível execução de malwares através da ferramenta `infocmp`.
- **Perda de Disponibilidade:** Serviços Perl dependentes de manipulação de arquivos tar podem travar ou consumir 100% de RAM.
- **Integridade do Sistema:** Manipulação indevida de permissões e terminação de processos críticos do sistema operacional.

Recomendações de Correção

1. **Atualização Crítica:** Aplique as atualizações disponíveis no repositório Debian para todos os pacotes listados (`apt update && apt upgrade mount util-linux ncurses-base ncurses-bin perl-base`).
2. **Validação de Versões:** Confirme que a versão `util-linux` foi atualizada para uma versão posterior à `2.41-5`, onde as CVEs 2026 são corrigidas.
3. **Revisão de `fstab` :** Verifique entradas no `/etc/fstab` que utilizam opções `X-mount.subdir`, `X-mount.owner` ou bind mounts restritos para mitigar riscos temporários até a atualização do kernel/util-linux.